

Microsoft Certified: Security Operations Analyst Associate

Course

Defend against cyberthreats with Microsoft's security operations platform

---

Module 1

Mitigate threats using Microsoft Defender XDR

Modules in this learning path

COURSE 6

Secure your cloud apps and services with Microsoft Defender for Cloud Apps

Introduction

When you move from an on-premises to a cloud-based organization, you increase flexibility, both for employees and the IT team. However, this move also introduces new challenges for keeping your organization secure. To get the full benefit of cloud apps and services, you have to balance supporting access with protecting critical data. Microsoft Defender for Cloud Apps helps you achieve that balance. It provides rich visibility, control over data travel, and sophisticated analytics to identify and combat cyberthreats across all your cloud services.

Suppose you're an administrator for an organization that's moved into the cloud. This module will show you how to use Microsoft Defender for Cloud Apps.

Learn objectives

When you finish this module, you'll be able to:

Define the Defender for Cloud Apps framework.

Understand how to use Cloud Discovery for visibility in your organization.

Explain how to use Conditional Access App Control policies to monitor and control access to your applications.

Understand how to classify and protect your information.

Understand how to use anomaly detection policies to detect threats in your cloud environment.

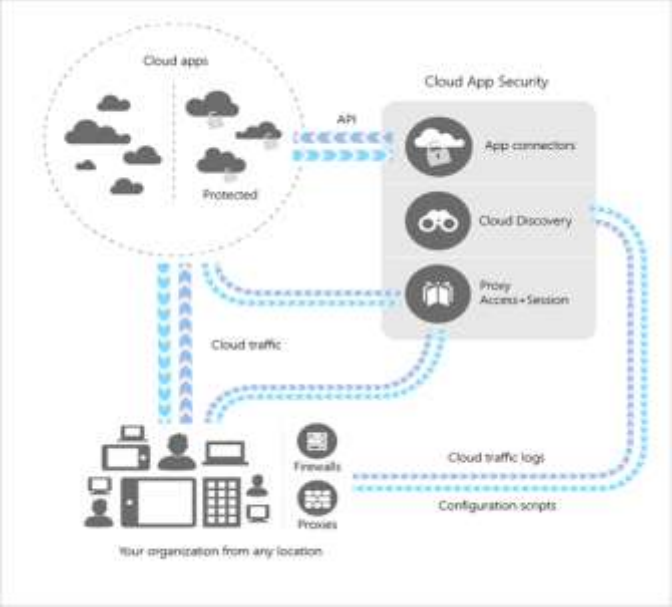
Understand the Defender for Cloud Apps Framework

Cloud access security broker (CASBs) are defined by Gartner as security policy enforcement points, placed between cloud service consumers and cloud service providers to combine and interject enterprise security policies as cloud-based resources are accessed. CASBs consolidate multiple types of security policy enforcement.

In other words, CASBs are the intermediaries between your users and all of the cloud services they access. CASBs help you to apply monitoring and security controls over your users and data. CASBs for cloud services are like firewalls to corporate networks.

Microsoft Defender for Cloud Apps is a CASB that helps you identify and combat cyberthreats across Microsoft and third-party cloud services. Microsoft Defender for Cloud Apps integrates with Microsoft solutions, providing simple deployment, centralized management, and innovative automation capabilities.

The following graphic shows the flow of information around your organization. You can see how Defender for Cloud Apps functions as an intermediary between apps, data, and users.



There are four elements to the Defender for Cloud Apps framework:

Discover and control the use of Shadow IT: Identify the cloud apps, IaaS, and PaaS services used by your organization. How many cloud apps do you think are used by your users? The apps you don't know about, on average totaling more than 1,000, are your "Shadow IT". When you know which apps are being used, you'll better understand and control your risk.

Protect your sensitive information anywhere in the cloud: Understand, classify, and protect sensitive information at rest. To help you avoid accidental data exposure, Defender for Cloud Apps provides data loss prevention (DLP) capabilities that cover the various data leak points that exist in organizations.

Protect against cyberthreats and anomalies: Detect unusual behavior across apps, users, and potential ransomware. Defender for Cloud Apps combines multiple detection methods, including anomaly, user entity behavioral analytics (UEBA), and rule-based activity detections, to show who is using the apps in your environment, and how they're using them.

Assess the compliance of your cloud apps: Assess if your cloud apps comply with regulations and industry standards specific to your organization. Defender for Cloud Apps helps you compare your apps and usage against relevant compliance requirements, prevent data leaks to noncompliant apps, and limit access to regulated data.

Explore your cloud apps with Cloud Discovery

You can use Cloud Discovery to see what's happening in your network. You'll see both the cloud apps you expect and the ones you don't, signs of Shadow IT, and nonsanctioned apps that might not be compliant with your security and compliance policies. Cloud Discovery analyzes your traffic logs against a catalog of more than 16,000 cloud apps. Cloud Discovery ranks each app and scores it based on more than 80 risk factors to give you visibility into cloud use, Shadow IT, and the risk it poses in your organization.

The Cloud Discovery dashboard provides an at-a-glance overview of what kinds of apps are being used, your open alerts, and the risk levels of the apps in your organization. You can also see who your top app users are and where

each app comes from (on an App Headquarters map). You can filter the data collected by Cloud Discovery to generate specific views depending on what interests you most.

Review the Cloud Discovery Dashboard

Your first step is to get a general picture of your cloud apps. Start at the Cloud Discovery dashboard then move through its elements in the following order to understand what's happening in your organization.

Start with the High-level usage overview to see the overall cloud app use. You can see the top users and source IP addresses. Based on this information, identify which users in your organization use cloud apps the most. You'll want to pay attention to these users going forward.

Dive one level deeper to see which category of apps your organization uses most. See how much of this usage is in Sanctioned apps.

Go even deeper on the Discovered apps tab. See all the apps in a specific category.

Review the risk score for the discovered apps in the App risk overview. Each discovered app is assessed against risk factors like security and compliance and regulatory measures. Apps are given a risk score between 1 and 10.

View where discovered apps are located (based on their headquarters) in the App Headquarters map.

If you find an app that poses a risk to your organization, you can flag it as Unsanctioned in the Discovered apps pane.

If your organization is using Microsoft Defender for Endpoint (or a similar solution), any unsanctioned app is automatically blocked.

If you don't have a threat protection solution, you can run a script against the data source to block the app. Then users will see a notification that the application is blocked when they try to access it.

Protect your data and apps with Conditional Access App Control

Cloud Discovery helps you understand what's happening in your cloud environment after the fact. While this process is important, your primary goal is to stop breaches and leaks in real time, before they put your organization at risk. You also need a way to enable users to bring their own devices to work while still protecting your organization from data leaks and data theft. Microsoft Defender for Cloud Apps integrates with identity providers (IdPs) to protect your data and devices with access and session controls through Conditional Access App Control. If you're using Microsoft Entra ID as your IdP, these controls are integrated directly into Defender for Cloud Apps.

Conditional Access App Control lets you monitor and control user app access and sessions in real time. By integrating with Microsoft Entra Conditional Access, it's easy to configure apps to work with Conditional Access App Control. It lets you selectively enforce access and session controls on your organization's apps based on any condition in Conditional Access. You can use conditions that define who (user or group of users), what (which cloud apps), and where (which locations and networks) a Conditional Access policy is applied. After you determine the conditions, you can route users to Defender for Cloud Apps where you protect data with Conditional Access App Control by applying access and session controls.

Microsoft Entra ID includes built-in policies that you can configure for an easy deployment. After you configure the conditions of a Conditional Access policy in Microsoft Entra ID, select Session under Access controls, and click Use Conditional Access App Control. If you choose to use custom controls, you'll define them in the Defender for Cloud Apps portal.

You can use access and session policies in the Defender for Cloud Apps portal to further refine filters and set actions to be taken on a user. With the access and session policies, you can:

Prevent data exfiltration: Block the download, cut, copy, and print of sensitive documents on, for example, unmanaged devices.

Protect on download: Instead of blocking the download of sensitive documents, you can require them to be labeled and protected with Azure Information Protection. This action ensures that the document is protected and that user access is restricted in a potentially risky session.

Prevent upload of unlabeled files: Enforce the use of labeling. Before a sensitive file is uploaded, distributed, and used by others, it's important to make sure that it has the right label and protection. You can block a file upload until the content is classified.

Monitor user sessions for compliance: Monitor risky users when they sign in to apps and log their actions from within the session. You can investigate and analyze user behavior to understand where, and under what conditions, to apply session policies in the future.

Block access: You can block access for specific apps and users depending on several risk factors. For example, you can block a user if they're using a client certificate as a form of device management.

Block custom activities: Some apps have unique scenarios that carry risk; for example, sending messages with sensitive content in apps like Microsoft Teams or Slack. In these kinds of scenarios, you can scan messages for sensitive content and block them in real time.

For example, let's create a session policy in Microsoft Teams that blocks IM messages containing sensitive content. Assuming we previously created a Conditional Access policy with Use custom controls set under Use Conditional Access App Control, we start by creating a new session policy in Microsoft Defender for Cloud Apps.

We'll use an existing template for our new session policy. Select the Block sending of messages based on real-time content inspection policy template.

Under Activity source for the session policy, select Send Teams message as the application.

You then enable Content Inspection, where you'll define the sensitive information as matching a present expression, a custom expression, or any regular expression. When the expressions are defined, select Block under Actions to block the message, and to create alerts to notify administrators.

Now, when a user tries to send a sensitive message in Teams, they'll see a notification.

Classify and protect sensitive information

One of the key elements of the Defender for Cloud Apps framework is protecting your sensitive information. Sensitivity is a subjective phrase, as this can vary from one organization to another.

Here, you'll understand how to find which apps are accessing your data, how to classify which information is sensitive, how to protect it from illegal access, and how to monitor and report on the overall health of your environment.

What is Information Protection?

An employee might accidentally upload a file to the wrong place. Or they could send confidential information to someone who shouldn't have it. As a result, information could be lost or made accessible to the wrong person. Any lost or wrongfully exposed information can have serious legal, financial, or reputational consequences for your organization. Information is vital to any modern organization, and you want to ensure that it's protected at all times.

To help you, Microsoft Defender for Cloud Apps natively integrates with Azure Information Protection, a cloud-based service that helps classify and protect files and emails across your organization.

Note

You have to enable the app connector for Microsoft 365 to take advantage of Azure Information Protection

You enforce information protection with Microsoft Defender for Cloud Apps through phases:

Phase 1: Discover data

During this phase, you make sure apps are connected to Microsoft Defender for Cloud Apps so it can scan for and classify data, then apply policies and controls. You can do this in two different ways: use an app connector, or use Conditional Access App Control.

Phase 2: Classify sensitive information

In this phase, you'll do the following:

Decide what counts as sensitive in the context of your organization. Microsoft Defender for Cloud Apps includes more than 100 predefined sensitive information types, and default labels in Azure Information Protection. Sensitive information types and labels define how to handle, for example, passport numbers and national/regional identity numbers. You can also use default labels in Azure Information Protection. These labels will be used by Microsoft Defender for Cloud Apps when scanning, to classify information. The labels are:

Personal: Data for personal, nonbusiness use only.

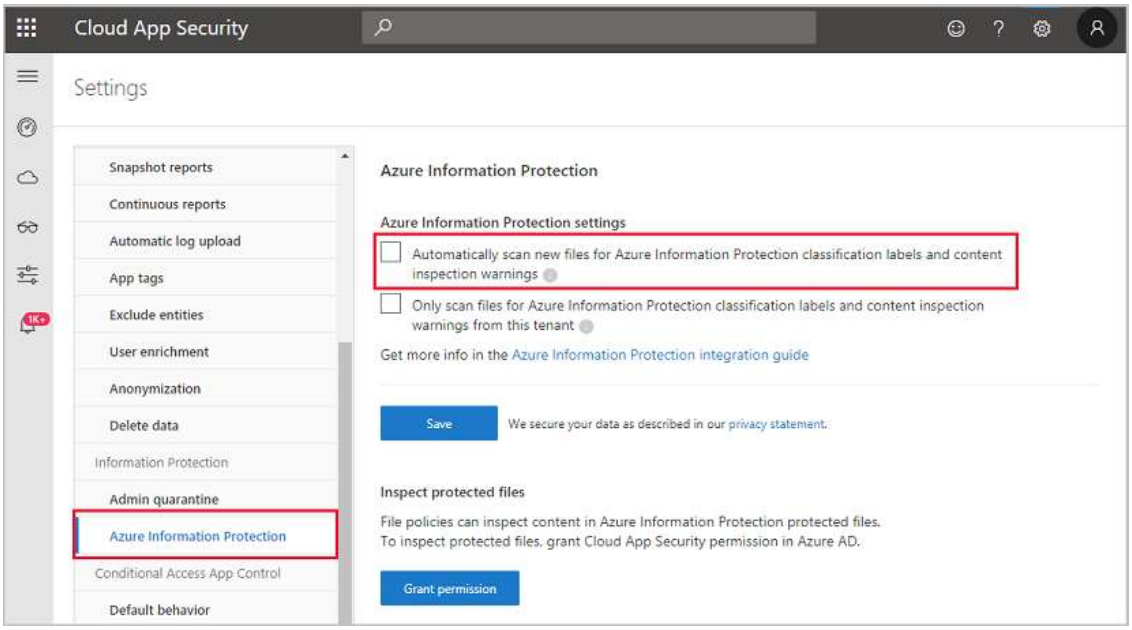
Public: Data that can be shared for public consumption, such as marketing posters and blog posts.

General: Data that can't be shared for public consumption, but can be shared with external partners. For example, project timelines and organizational charts.

Confidential: Data that could damage the organization if it's shared with unauthorized people. For example, sales account data and forecasts.

Highly confidential: Very sensitive data that will cause serious damage if shared with unauthorized people. For example, customer details, passwords and source code.

Enable Azure Information Protection integration in Microsoft Defender for Cloud Apps by selecting Automatically scan new files for Azure Information Protection classification labels in the Settings pane:



Phase 3: Protect data

There are different types of policies you can create to detect sensitive information and act accordingly. For example, you can create a File policy to scan the content of files in your apps in real time, and for data at rest. File policies let you apply governance actions. You can then automatically:

Trigger alerts and email notifications.

Change sharing access for files.

Quarantine files.

Remove file or folder permissions.

Move files to a trash folder.

To create a file policy

Open Microsoft Defender for Cloud Apps

Select the Control pane

Select Policies > Create policy

Select File policy

When the form that appears, you'll fill in the following fields:

Field	Description
Policy severity	Defines how important the policy is and whether to trigger a notification. The severity of the policy can be customized to quickly identify the risk associated with a policy match.
Category	This is an informative label that you assign to the policy to help locate it later. By default, for File policies is DLP.
Create a filter for the files this policy will act on	It is used to decide which apps will trigger the policy. Ideally this should be defined to be as narrow as possible to avoid false positives.
Apply to (1st)	Select which discovered apps will trigger the policy. There are two choices: - All files excluding selected folders: to apply the policy to all files. - Selected folders: to apply the policy to apps like Box, SharePoint, OneDrive, and Dropbox.
Apply to (2nd)	Select which users and groups should be included in this policy. There are three options: - All file owners - File owners from selected user groups - All file owners excluding selected groups
Content inspection method	Select how you want files to be inspected. There are two options: - Built-in DLP - Data Classification Services (DCS) Microsoft recommends DCS as this will allow you to use a unified labeling experience across Microsoft 365, Azure Information Protection, and Microsoft Defender for Cloud Apps.
Governance	Select which governance actions you want Microsoft Defender for Cloud Apps to perform when a match is detected.

When you're done, select Create to create your file policy.

Phase 4: Monitor and report

Check your dashboard to monitor for alerts and the overall health of your environment. For example, to review file-related alerts, go to the Alerts pane, and select DLP in the Category field.



You can investigate a file-related alert to better understand what caused it to be triggered. Or you can dismiss an alert that you determine could be ignored. You can also export your alerts to a CSV file for further analysis.

Detect Threats

When you understand how to protect data from accidental exposure, the next thing to consider, and one of the elements of the Defender for Cloud Apps framework, is protecting against cyberthreats and anomalies.

Microsoft Defender for Cloud Apps includes out-of-the-box anomaly detection policies that utilize user and entity behavioral analytics (UEBA) and machine learning to provide advanced threat detection across your cloud environment. It's important to note that anomaly detections are nondeterministic by nature. These detections only trigger when there's behavior that deviates from the norm.

Although anomaly detection policies are automatically enabled, Microsoft Defender for Cloud Apps spends the first seven days learning about your environment. It looks at the IP addresses, devices, and locations your users access, identifies which apps and services they use, and calculates the risk score of all of these activities. This process contributes to the baseline, against which your environment and any alerts are compared. The detection policies also use machine learning to profile your users. If Microsoft Defender for Cloud Apps recognizes your users and their normal sign-in patterns, it can help reduce false positive alerts.

Anomalies are detected by scanning user activity and evaluating it for risk. The risk is evaluated by looking at more than 30 different indicators, grouped into the following risk factors:

Risky IP address

Login failures

Admin activity

Inactive accounts

Location

Impossible travel

Device and user agent

Activity rate

Microsoft Defender for Cloud Apps looks at every user session on your cloud and alerts you when something happens that's different from the baseline of your organization, or from the user's regular activity.

Anomaly detection policy overview

The Microsoft Defender for Cloud Apps anomaly detection policies is configured to detect various security issues. The most popular are:

Impossible travel. Activities from the same user in different locations within a period that's shorter than the expected travel time between the two locations.

Activity from infrequent country. Activity from a location that wasn't recently or never visited by the user, or by any user in the organization.

Malware detection. Scans files in your cloud apps and runs suspicious files through Microsoft's threat intelligence engine to determine whether they're associated with known malware.

Ransomware activity. File uploads to the cloud that might be infected with ransomware.

Activity from suspicious IP addresses. Activity from an IP address identified as risky by Microsoft Threat Intelligence.

Suspicious inbox forwarding. Detects suspicious inbox forwarding rules set on a user's inbox.

Unusual multiple file download activities. Detects multiple file download activities in a single session with respect to the baseline learned, which could indicate an attempted breach.

Unusual administrative activities. Detects multiple administrative activities in a single session with respect to the baseline learned, which could indicate an attempted breach.

Configure an anomaly detection policy

Now that you learned about the anomaly detection policies, let's configure a discovery anomaly policy so you can see the steps to set it up and configure it for your environment. A discovery anomaly detection policy looks for unusual increases in cloud application usage. It looks at increases in downloaded data, uploaded data, transactions, and users for each cloud application. Then, each increase is compared to the baseline for the application. The most extreme increases trigger security alerts.

You can set filters to customize how you monitor application usage. Filters include an application filter, selected data views, and a selected start date. You can also set the sensitivity, which enables you to set how many alerts the policy should trigger.

Fine-tune anomaly detection policies for suppression or surfacing alerts

Although anomaly detections only trigger when something happens outside the norm, they're still susceptible to false positives. Too many false positives can lead to alert fatigue, and you risk missing the important alerts in the noise. To help prevent alert noise, you can fine-tune the detection logic in each policy to include different levels of suppression to address scenarios that can trigger false positive, such as VPN activities.

When creating or editing an anomaly detection policy, you determine its sensitivity according to the type of coverage you need. A higher sensitivity uses stricter detection logic algorithms. This allows you to adapt your detection strategies for each policy.

Before you fine-tune your policies, it helps to understand the options for suppressing an alert. There are three types of suppression:

Suppression type	Description
System	Built-in detections that are always suppressed.
Tenant	Common activities based on previous activity in the tenant. For example, suppressing activities from an ISP previously alerted on in your organization.
User	Common activities based on previous activity of the specific user. For example, suppressing activities from a location that is commonly used by the user.

The sensitivity levels affect the suppression types differently:

Sensitivity Level	Suppression types affected
Low	System, Tenant, and User
Medium	System, and User
High	System Only

You can also configure whether alerts for activity from infrequent country/region, anonymous IP addresses, suspicious IP addresses, and impossible travel should analyze failed and successful logins, or successful logins.

Adjust the anomaly detection scope policy to users and groups

Each anomaly detection policy can be independently scoped so that it applies only to the users and groups you want to include and exclude in the policy. For example, you can set the Activity from infrequent country/region detection to ignore a specific user who travels frequently.

To scope an anomaly detection policy:

Sign in to the Microsoft Defender Portal through your browser.

In the navigation menu, expand the Cloud apps section, and select Policies.

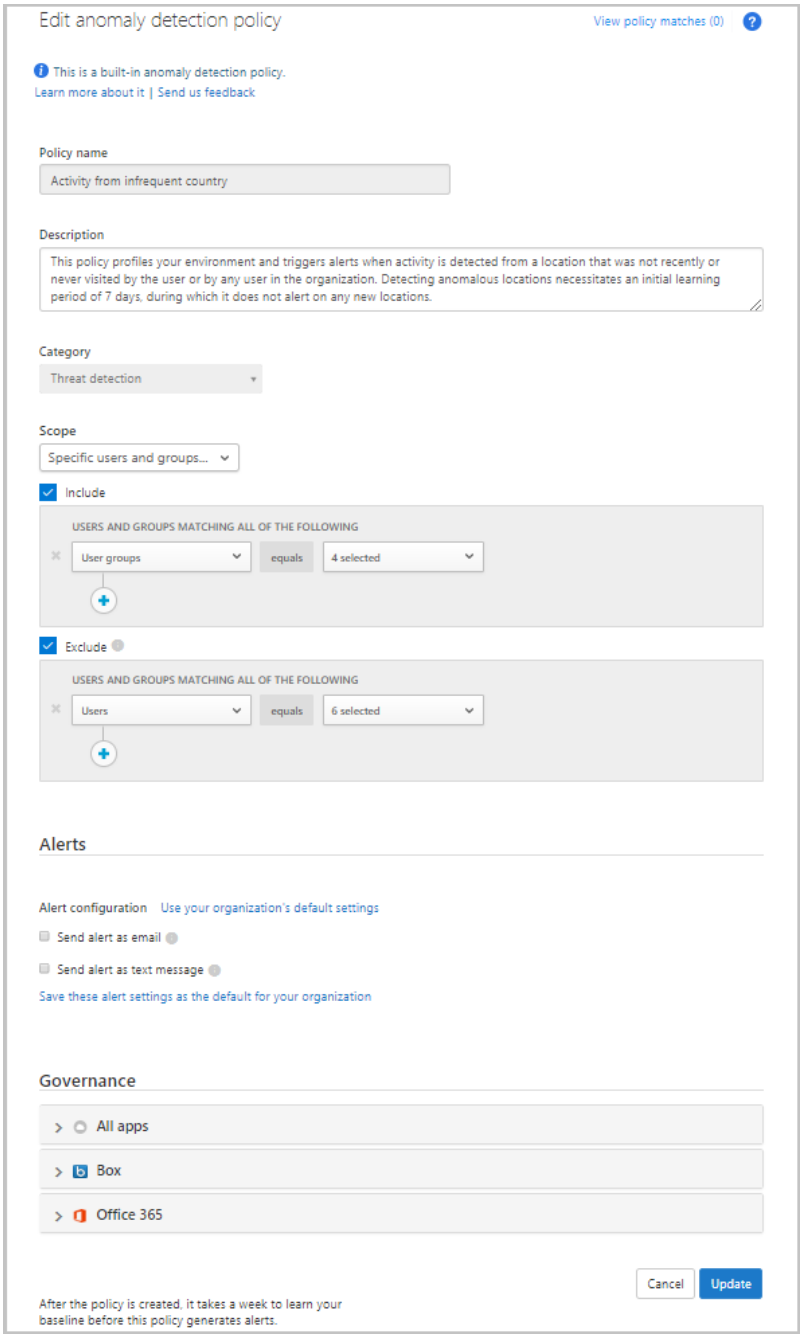
Select Policy management, and set the Type filter to Anomaly detection policy.

Select the policy you want to scope.

Under Scope, change the dropdown from the default setting of All users and groups, to Specific users and groups.

Select Include to specify the users and groups for whom this policy applies. Any user or group not selected here won't be considered a threat or generate an alert.

Select Exclude to specify users for whom this policy won't apply. Any user selected here won't be considered a threat or generate an alert, even if they're members of groups selected under Include.



When you've completed the changes to the scope, select Update to commit the change.